

BGP DEC Resolution — Answered

docs/blueprint/BGP_DEC_Resolution_Intake_2026-09-25_ANSWERED.md

Companion to `BGP_DEC_Resolution_Intake_2026-09-25.md`. Same six decisions, same sub-questions, answered in place of each `> _answer here_` line. Where a question exposed a problem with the framing itself, that's noted before the answer rather than forced into it.

DEC05 — Durability envelope and mechanism (Operations/security leads)

Recommendation: neither candidate as originally framed. Candidate A+.

Candidate B's pending-and-reconcile pattern shows the user a "Pending" state after every Approve click. In a product whose entire

value proposition is "this decision is definitely recorded," that is the worst possible UX at the worst possible moment. Candidate A's actual cost — a synchronous commit to a standby in another zone — is roughly 1–3 ms on managed Postgres, which is not a real cost to avoid.

Candidate A+: synchronous durable replication before acknowledgement (clean, truthful "Recorded" response), plus an *asynchronous* independently-protected hash-chain anchor for tamper-evidence. Candidate B's pending state survives only as the labelled degraded fallback when the sync replica is unavailable — the gate does not display as decided until confirmed.

1. **Candidate.** A+ (above), not A or B as originally posed.

2. **Failure scenarios covered.**

Zero loss for acknowledged decisions: process crash, node failure, storage failure, single-zone failure. Regional failure covered by continuous archiving to a second region at

RPO $\leq$ 5 minutes, restored inside RTO. Explicitly **not** covered by durability alone: logical corruption from a code defect or an authorised-but-malicious write — these are *detected* by the hash chain and *recovered* by point-in-time restore, not prevented by replication. Also not covered: simultaneous loss of the primary region and its archive.

3. Independence of the integrity-verification mechanism.

Yes. The chain anchor writes to object-lock (WORM) storage under a credential the application database role cannot overwrite or delete, and the verification job runs under a third, separate identity. If the app role could rewrite the anchor, the tamper-evidence claim would be theatre, not a control.

4. Numeric availability target.

Availability 99.5% monthly. Acknowledged decisions: RPO 0 in-region, $\leq$ 5 min cross-region. RTO 8 hours. Quarterly restore test into a clean environment. Integrity verification runs at least

daily; a chain mismatch is treated as an S1 incident, acknowledged within 1 hour.

5. Acknowledgement point.

Synchronous ack. The API returns success only when the decision row, its audit entry, and its chain link are committed in one transaction and confirmed on a same-region, different-zone synchronous replica. A pending state is a visible, alerting, degraded condition (alert past 5 minutes) and never counts as a recorded decision.

DEC06 — Retention, disposal and attribution (Privacy reviewer/owner)

6. Retention period(s) — uniform, or different per record type?

Different per type, as a floor tenants may lengthen but not shorten:

- Decisions, gate approvals, exceptions — 7 years after Gate 6

- Requirements, designs, acceptance and release records — life of the service plus 3 years, never less than 7 years after Gate 6
- Audit events — 7 years after Gate 6 or after the event, whichever is later
- **Attachment bytes — shortest of all, default 3 years, tenant-configurable, purgeable early** while the metadata and hash survive

That last split — attachment bytes separated from the record that references them — is what makes the rest of this table workable at all.

7. Retention/disposal vs. permanently un-deletable decisions — is there a genuine exception, and for which tables?

One narrow, genuine exception. Separate three things: the structural decision fact, personal data inside it, and attachment bytes.

Structural fields — actor id, timestamp, action, before/after hashes — are **never** mutable, in `decisions`,

`gate_decisions` and `audit_events`. Redaction is permitted only on named personal-data fields and on attachment bytes, and is implemented as a *redaction event*: the value is replaced by a marker, the chain is re-anchored, and the authoriser is recorded. The chain proves a redaction happened without revealing what was redacted.

Store the actor as a stable pseudonymous id with the id-to-person mapping in one separately-redactable table, so an erasure request can be honoured without breaking a single chain. At true end of retention, disposal removes the row set and leaves a tombstone: record id, hash, disposal date, authoriser, method.

8. Legal-hold mechanism — who can place one, what does it override?

Placed by the tenant's named records custodian or data owner, and by the project sponsor. The platform operator may place one only on written legal instruction, and the tenant is shown that it exists.

It overrides all scheduled disposal, any tenant-configured shortening, and attachment purge. It does **not** override a legally compelled erasure request — that case stops and is routed to qualified legal advice instead of being resolved by this mechanism.

Mandatory fields: scope, reason, owner, placed date, release condition.

Release requires the same role and its own record.

9. Other attribution/disposal specifics.

- A deleted user keeps attribution via a stable id plus a display-name snapshot taken at the time of the action, so no decision is ever orphaned.
- Exports leaving the tenant are pseudonymous by default.
- State the backup truth plainly to tenants: disposal is effective in live data within 24 hours and in backups within the backup retention window. Promising instant deletion from backups would be a false claim.

DEC07 — Rule vocabulary and third framework (Technical lead)

10. Is the current vocabulary (eq/in/all/any), max condition depth 5, no eval/exec, approved as-is, or does something change?

Approved as-is, plus three additions and two tightenings.

Add: `not` (without negation, authors write contorted rules to fake it); `gte` / `lte` for dates and counts; `count(...)` with a comparison, because "at least N of these complete" is a genuinely common governance rule.

Tighten: cap total condition nodes at 200 in addition to the depth-5 limit, and add a hard evaluation timeout. Rules must be pure functions of project state plus a supplied "as at" timestamp — no external calls, no wall-clock reads inside the rule itself.

Stamp `vocabulary_version` on every template version so old templates

evaluate identically forever, regardless of later vocabulary changes.

Resist adding anything beyond this: every operator added is another thing the guided authoring UI has to explain to a beginner.

11. What's the third permitted framework fixture (beyond the two already built)?

The two existing fixtures are both gate-based and from the same house, so they prove very little about generality. The third must be structurally different: an **agile Definition-of-Ready / Definition-of-Done framework with no gates at all** — recurring per-increment checks, unnumbered, evaluated every sprint rather than at a fixed checkpoint. If the rule engine and data model survive that without a special case, the model is genuinely general.

Second choice, if an external standard is preferred instead of an in-house agile fixture: NIST SSDF 800-218 practice groups.

12. What's its permitted scope – full parity with the other two, or narrower?

Full parity on the model: tracks, items, rules, roles, statuses, decisions. A narrower fixture proves nothing, which defeats the purpose of building a third one at all. Mark it a **validation fixture**, not a shipped starter template, until it has passed its own review.

DEC08 – Usability sample and performance budgets (UX/technical leads)

13. Sample size per user group (beginner/contributor/client approver/administrator, including disabled and older-device users).

Beginner 8, contributor 5, client approver 5, administrator 5 – 23 total. Five per group is the standard threshold for surfacing most usability issues; beginners get eight because the twenty-minute

first-gate test is a release blocker and warrants tighter confidence.

Don't run disabled users as a separate fifth group — distribute them:

at least 5 participants using assistive technology spread across the four groups, plus a dedicated expert accessibility review. At least 6 participants on older or low-end devices, similarly distributed.

14. Device/network profiles to test against.

Primary budget target: mid-range Android on Fast 3G (1.6 Mbps, 150 ms RTT) — the realistic Ghanaian mobile case.
Degraded acceptance case:
low-end Android (~4 GB RAM, 2019-era hardware) on Slow 3G (400 kbps, 400 ms RTT), which must stay **usable**, not fast.

Also test: an iPhone two or three generations old on 4G; desktop
broadband as baseline; 320 px and 360 px viewport widths; 400% zoom
reflow for WCAG 1.4.10.

15. Numeric API p95 latency budget?

Server time at origin, excluding client network:

- Reads (gate view, dashboard): p95 $\leq$ 300 ms, p99 $\leq$ 800 ms
- Ordinary writes: p95 $\leq$ 500 ms
- Decision writes: p95 $\leq$ 800 ms, p99 $\leq$ 1.5 s
— this is the allowance the DEC05 synchronous replica commit needs
- Exports: asynchronous; must begin streaming within 2 s

16. Numeric page/render budget?

Critical render path $\leq$ 170 KB compressed.
 Total first load $\leq$ 350 KB;
 heaviest authoring screen $\leq$ 1 MB. LCP $\leq$ 2.5 s
 on the primary profile and
 $\leq$ 5 s on the degraded profile. INP $\leq$ 200 ms.
 CLS $\leq$ 0.1. No more than two
 blocking requests before first render. All of this
 enforced in CI as a
 blocking budget check, not a dashboard
 someone reads occasionally.

DEC11 — Operator access and key custody (Security lead/owner)

17. Break-glass scope — what can an operator do in an emergency that they can't do routinely?

Routine operator access: tenant metadata, aggregate health, error traces with tenant content redacted — **never** evidence, attachments, decision content or personal data.

Break-glass adds, time-boxed to one incident: read specific rows for one named incident; read one attachment only where the incident concerns that specific attachment; run a scoped data-fix migration. It never permits editing or deleting a decision, disabling audit, exporting a whole tenant, or touching more than one tenant in a session. Sessions expire in 60 minutes, bound to one tenant and one incident id, with every query logged.

18. Approval path required for break-glass access.

Two-person rule. Requester plus an approver who is not the requester and holds Security Lead or Executive/Service Owner. Out of hours, mirror the existing emergency-change control: named Service Owner as primary authority, Technical Lead or on-call engineer as deputy.

An incident id is mandatory; if none exists yet, one is created first.

Approval is recorded **before** access — or, if the granting system is itself down, a recorded verbal approval with written confirmation inside 24 hours. Retrospective review within 72 hours, matching the SDLC emergency-change procedure already in place.

19. Tenant-visibility rule for operators in the break-glass case.

Given the project's privacy-by-architecture stance, notification-only is too weak to be the default. **Tenant pre-approval is the default**, with a narrow carve-out for life-safety and legal-compulsion cases, where access proceeds immediately and the tenant is notified at the moment the session opens.

Either way: the session appears in the tenant's own audit log — who, when, incident, scope, what was read, approver, close time. A report follows within 72 hours. No suppression window, no silent access,

ever. This is a differentiator worth advertising, not a cost to minimise.

20. Independent key-custody arrangement — who holds keys separately from the operator role?

Three separate identities against a managed KMS or HSM:

- **Application role** — can request decrypt, cannot export, rotate or delete keys
- **Key custodian** — can rotate and create keys, cannot read application data
- **Operator role** — holds neither of the above powers

Custodian is a named person distinct from on-call, with a named deputy in the runbook. Backup-encryption keys and the chain-anchor write credential live in a separate account from production under object-lock, so even the custodian cannot delete anchors inside their retention period. Key deletion or rotation requires the same

two-person approval as break-glass, and key custody is reviewed as part of the quarterly access review.

DEC12 – Migration of legacy tracker records (Data owner)

21. Is kenAddme the actual Data Owner, or does this policy require substitute data owner sign-off with someone else?

Yes, with one distinction that carries legal weight, not just terminology. KenAddme IT Links is the data owner and controller for records it created for its own purposes, with Freston Kenny Adedeme as named custodian.

But the legacy tracker also holds material about **client** projects.

Where a record contains client personal data processed on the client's instruction, the client is controller and KenAddme is processor for that record. Classify the import **per record set, not wholesale,**

and carve out any client-owned records that need client authorisation before import.

Also record the platform-side split explicitly, since it's a mirror image of the above: on the platform itself, the tenant is controller and the operator is processor — so KenAddme-as-tenant is data owner of its own tenant data, while KenAddme-as-operator is not.

22. When a real (non-synthetic) import happens, what substantive authorisation/reconciliation evidence will accompany it?

Before:

- Written import authorisation from the data owner naming source system, record set, lawful basis, destination tenant, data classification, and any client consents
- Source data inventory: counts by type, date range, personal-data fields
- Privacy screen confirming no Restricted data, or documented approval

if there is

- Dry run into non-production with the reconciliation report reviewed

During:

- A dedicated, time-limited migration identity – not an operator or application role – with every write tagged with a batch id

After:

- Counts, source vs. destination, by type, with a zero-variance statement or an explained variance list
- Hash comparison of normalised source rows
- Manual field-by-field verification of the greater of 10% or 30 records, performed by someone other than the person who ran the import
- A new chain checkpoint covering the imported set
- The source frozen read-only at the cut-over timestamp

The one requirement that matters most: every imported decision must

carry its **original** actor and timestamp. Any record lacking one is imported as `attributed: unknown, migrated` — never assigned to whoever ran the import. Every imported row is flagged `origin: migrated` permanently, so no one later mistakes a reconstructed record for one captured live.

Sign-off: data owner plus an independent reviewer, recorded as a change record rather than a routine operation.

Open items — not answered above by design

- **DEC05 candidate framing.** Answered as A+, a synthesis not offered as an option in the original intake. Flag this explicitly at review — it changes what Operations/security leads are being asked to approve.
- **DEC11 Q19 break-glass default.** Pre-approval vs. notification-only is a genuine trade-off between privacy posture and incident-response speed. The recommendation favours privacy given this project's stated principles, but

it is Security lead/owner's call to make, not a settled fact.

- **DEC07 Q11 third fixture.** The no-gate agile fixture is deliberately the harder test. It is more likely to surface real gaps in the rule/data model than a second gate-based framework would — that is the point of choosing it, and it should be expected to cost more time, not less.